FinReq Sprint Plan: AI Proposal and Team Revision

Course: Senior Project II | **Team:** Group 3

Members: Jean Joiles, Ibrahim Osman, Janelle Yankey, Nylah Rogers, Jaz Taylor

Sprint: Sprint 1, two weeks, November 2 to November 13, 2026

Repository: github.com/jjoiles/Financial_Management_System_Group3 (main at commit `112d97f`)

Contents

1. How the plan was produced
2. Agent output (raw, unedited)
3. Human revision: what we changed and why
4. Final sprint plan: goal, scope, assignments, dependencies, risks
5. AI plan vs final plan at a glance

1. How the Plan Was Produced

Context given to the agent: the full repository (source, `docs/DEBT_AND_RISK.md`, the six Supabase migrations, feature docs F2 to F22) plus the list of open GitHub issues (#12 to #109) and open pull requests (#116, #117, #119, #121).

Prompt (verbatim):

```
You have access to the FinReq repository (Financial_Management_System_Group3), including
docs/DEBT_AND_RISK.md, the Supabase migrations, src/, and the open GitHub issues and pull
requests. Our team has five members (Jean Joiles, Ibrahim Osman, Janelle Yankey, Nylah
Rogers, Jaz Taylor) and a two-week sprint. Propose a sprint plan with: (1) a sprint goal,
(2) sprint backlog candidates with size estimates, (3) risks and dependencies. Do not
write any code.
```

Review process: the team checked every agent claim against the repository and GitHub (file contents, git history, PR merge status, issue list) before accepting, changing, or rejecting it. Section 3 records each change and the evidence behind it.

2. Agent Output (Raw, Unedited)

AI OUTPUT, NOT EDITED BY THE TEAM

```
SPRINT GOAL
Stabilize the FinReq platform for production readiness by repairing Supabase
authorization, removing prototype fallbacks, hardening security and configuration,
establishing automated testing and CI, and delivering Role-Based Access Control (F21).

SPRINT BACKLOG CANDIDATES
1.  Repair Supabase authorization (#106, #107) - M
    Add a migration re-granting EXECUTE on has_role and is_admin_or_reviewer
    to the authenticated role.
2.  Remove prototype localStorage fallback (#106) - M
3.  Secure environment configuration (#103, #108) - S
    Add .env to .gitignore, create .env.example, remove demo credentials
    from login.tsx.
4.  Set up automated test infrastructure (#104) - M
    Install Vitest and Testing Library, add a test script, write tests for
    the Zod requestSchema.
5.  Continuous integration pipeline (#109) - S
    GitHub Actions running typecheck, lint, build, and test.
6.  Merge open pull requests #116, #117, #119, #121 - S
7.  Implement RBAC (F21: #21, #67-#71, #85-#102) - L
    Roles, permission matrix, route guards, RLS enforcement, tests.
8.  File upload validation and security (F3: #46-#62) - L
9.  Replace mock analytics data with live Supabase aggregation queries - L
10. Notifications table and real notification feed - M
11. Pagination on financial request queries - M
12. Filtering, sorting and search (F12, #12) - M
13. Audit-ready and immutable audit logs (F13 #13, F20 #20) - M
14. Security headers via Cloudflare _headers / wrangler config - S
15. Error monitoring with Sentry - M
16. Replace dangerouslySetInnerHTML QR code with qrcode.react - S
17. Accessibility (WCAG 2.1 AA) fixes on forms and header - M
18. Business rules engine verification (F1: #25-#36) - M

SUGGESTED OWNERS (based on current issue assignees)
- Jean Joiles:    6 PR merges, 12 Filtering/Sorting, 14 Security headers
- Ibrahim Osman:  1 Supabase authorization, 7 RBAC, 18 Business rules
- Janelle Yankey: 2 Prototype fallback, 8 File upload
- Nylah Rogers:   4 Testing, 5 CI, 13 Audit logs, 15 Sentry
- Jaz Taylor:     3 Env config, 9 Analytics, 10 Notifications, 11 Pagination,
                  16 QR code, 17 Accessibility

RISKS AND DEPENDENCIES
- Supabase migration changes could affect existing data; test before applying.
- RBAC is large and may not finish within the sprint.
- Lovable.dev regeneration may overwrite manual changes.
- Removing the prototype fallback may break the UI if the database is not working.
- Merge conflicts between parallel feature branches.
- Team availability around midterms.
- Dependencies: CI depends on test infrastructure; analytics depends on real data.
```

3. Human Revision: What We Changed and Why

TEAM REVISIONS

We kept the agent's core direction (fix authorization first, remove the prototype fallback, add CI) and its correct diagnosis of the revoked `EXECUTE` grants. We changed the following after checking the repository.

#	Agent said	What we found	Our change
1	Goal with five outcomes ("production readiness")	Five outcomes is a theme, not a goal. It cannot be demoed or judged done at sprint review.	One testable goal: a real user's request is saved to and read from Supabase with roles enforced in the database.
2	18 backlog items, 3 Large	Far over capacity for five part-time students in two weeks. Our project board has a WIP limit of 5.	10 committed items (all XS to M), 2 stretch items, 9 deferred with reasons.
3	Item 4: "Set up test infrastructure, install Vitest"	Already done. `package.json` has `"test": "vitest run"` and the repo has test files (`request-utils.test.ts` , `submission-service.test.ts` , `browser-submission.test.ts`).	Rescoped #104 to tests for `src/lib/validation/request-schema.ts` only (S9).
4	Item 6: "Merge open PRs #116, #117, #119, #121" (size S)	PR #119 cannot merge: GitHub reports it as conflicting. Commit `112d97f` on main already split `submit.tsx` into `submission-service.ts` and `browser-submission.ts` . Merging #119 would create two service layers.	S2: review #116, #117, #121 normally; for #119, Janelle and Ibrahim compare it with main and either close it or rebase only the non-duplicated parts.
5	Item 3: "Add .env to .gitignore"	`.env` is already tracked in git (committed in `84923c0`). Adding it to `.gitignore` alone changes nothing.	S7 adds `git rm --cached .env` . The keys are Supabase publishable keys, which are designed for client use, so the real protection is working RLS (S3, S6), not secrecy.
6	RBAC and fallback removal listed with no ordering	Every RLS policy calls `has_role` or `is_admin_or_reviewer` . RBAC cannot be tested and the fallback cannot be removed until the grant migration lands.	Explicit dependencies: S3 blocks S4, S5, S6. S2 blocks S4 because the fallback code lives in files touched by the open PRs.
7	Duplicates noted only for #106/#107 and #103/#108	Issues #37 to #45 duplicate #25 to #33, and #91 to #93 duplicate #85 to #87. Issue #109 overlaps #104.	S1: close duplicates and fill Priority, Size, and Iteration fields so the board matches this plan.
8	Item 15: Sentry error monitoring	F5 already added `src/lib/logger.ts` . Sentry adds an external account and is not needed for the goal.	Deferred. S4 routes fallback errors through the existing logger instead.
9	Item 18: Business rules verification (F1)	F1 overlaps the F8 routing engine already merged in PR #111.	Deferred until the team confirms what F1 still requires beyond F8.

10	Owners by issue assignee; Jaz given 6 items, Nylah 4	Unbalanced load, and Jaz's items depended on work owned by others.	Each member owns 2 committed items plus review duty. The person who wrote code removes or tests it (Janelle removes the fallback; Ibrahim reviews #119).
11	No acceptance criteria or definition of done	Items could not be judged complete.	Acceptance criteria per item and a sprint-wide definition of done.
12	Risks listed without likelihood, mitigation, or owner	Not actionable.	Risk register with likelihood, impact, mitigation, and owner (Section 4.6).

4. Final Sprint Plan

4.1 Sprint Goal

By November 13, a signed-in Howard requester can submit a financial request that is stored in and read back from Supabase, with no localStorage fallback, and with each role's access enforced and tested at the database level.

Demo test: Jean submits a request as a requester, a reviewer sees it, the row exists in Supabase, and the browser's localStorage holds no request data.

4.2 Sprint Backlog and Assignments

Size: XS under 2 hrs, S about half a day, M one to two days.

ID	Item (issues)	Owner	Size	Depends on	Acceptance criteria
S1	Board cleanup (#107, #108, #37 to #45, #91 to #93)	Jean	XS	None	Duplicate issues closed with a link to the kept issue; every sprint item on the board with Priority, Size, and Iteration set; no more than 5 items In Progress.
S2	Resolve open PRs #116, #117, #119, #121	Janelle (reviewers: Ibrahim for #119, Nylah for #121)	S	None	Each PR merged or closed with a written reason; main builds and `npm test` passes after the last merge.
S3	Auth repair migration (#106, part 1)	Ibrahim	S	None	New migration grants `EXECUTE` on `has_role` and `is_admin_or_reviewer` to `authenticated` only; on a local Supabase instance a requester can insert and read their own request; `anon` is still denied.
S4	Remove prototype fallback (#106, part 2)	Janelle	M	S2, S3	No references to `prototype-financial-requests` or `prototype-request-attachments` in `src/`; `prototype` flag removed from types; a failed insert shows an error to the user and is logged through `logger.ts`; tests updated and passing.

S5	RBAC role matrix (F21.1: #67, #88 to #90)	Ibrahim	S	S3	Permission matrix for `requester`, `reviewer`, `leadership`, `admin` covering requests, attachments, workflow events, and files; defined behavior for a user with no role; committed to `docs/`.
S6	RBAC database tests (F21.4, F21.5: #97, #98, #100 to #102)	Nylah	M	S3, S5	At least one allowed and one denied case per role per table in the matrix, plus one direct-API bypass attempt; tests run in CI.
S7	Secure config (#103)	Jaz	XS	None	`.env` untracked and in `.gitignore`; `.env.example` with placeholders and setup steps; login fields empty on page load.
S8	CI pipeline (#109)	Nylah	S	S2	GitHub Actions runs install, typecheck, lint, test, and build on every PR; shown blocking one deliberately failing test; branch protection requires it.
S9	Request schema tests (#104, rescoped)	Jaz	S	S2	A passing and a failing case for each rule in `request-schema.ts`: Howard email domain, conditional grant number, "Dr." prefix, date limits, amount limits; runs in CI.
S10	End-to-end verification and demo	Jean	S	S4, S6	Demo test in 4.1 passes on the deployed app; screenshots and Supabase row evidence saved for sprint review.

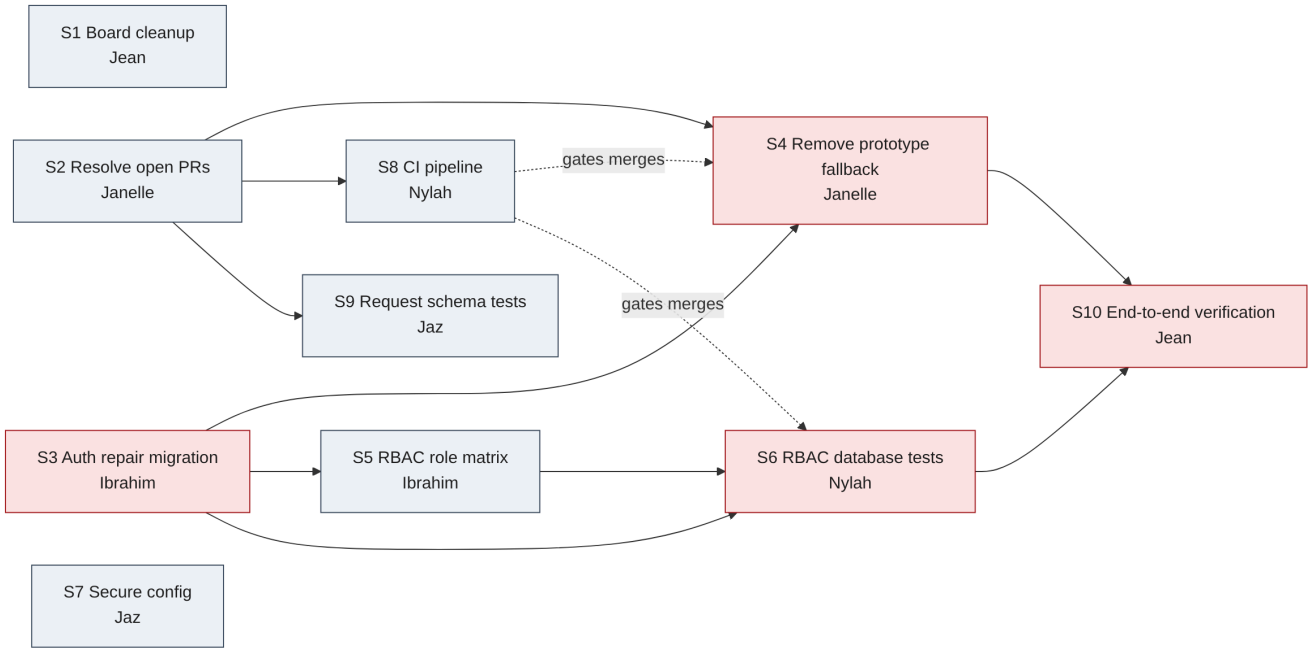
Stretch (only after own committed items are done): X1 security headers in `wrangler.jsonc` (Jaz); X2 replace `dangerouslySetInnerHTML` QR code in `login.tsx` (Janelle).

4.3 Workload by Member

Member	Committed items	Review duty	Stretch
Jean Joiles	S1 (XS), S10 (S)	S7, S9	None
Ibrahim Osman	S3 (S), S5 (S)	PR #119, S4	None
Janelle Yankey	S2 (S), S4 (M)	S3	X2
Nylah Rogers	S6 (M), S8 (S)	PR #121, S5	None
Jaz Taylor	S7 (XS), S9 (S)	S8	X1

4.4 Dependencies

Red items are on the critical path to the sprint goal. Dashed lines: CI must be in place before S4 and S6 merge.



Critical path: S3 → S5 → S6 → S10. S3 has no dependencies and starts Day 1. S1, S2, S3, and S7 all start Day 1 in parallel.

4.5 Schedule

Days	Target
Nov 2 to 3	S1, S2, S3, S7 complete
Nov 4 to 6	S5, S8, S9 complete; S4 and S6 in progress
Nov 9 to 11	S4, S6 merged behind CI; stretch items if capacity allows
Nov 12 to 13	S10 verification, sprint review and retrospective

4.6 Risk Register

Risk	Likelihood	Impact	Mitigation	Owner
Grant migration fails or widens access on the shared Supabase project	Medium	High	Run on a local Supabase instance first; S6 tests confirm denied cases before applying to the shared project.	Ibrahim, Nylah
Removing the fallback exposes errors users never saw before	High	Medium	Intended. S4 shows a clear message and logs it; merge only after S3 is live.	Janelle
PR #119 and main's refactor conflict, delaying S4	High	Medium	Resolve #119 on Day 1 as part of S2, with Ibrahim as reviewer.	Janelle, Ibrahim
Lovable.dev sync overwrites hand-written changes	Medium	High	No Lovable edits during the sprint; all changes go through PRs with CI.	Jean
Role matrix (S5) slips and blocks S6	Low	High	S5 kept small (document only) and due Nov 4; Nylah drafts test scaffolding against the existing RLS policies meanwhile.	Ibrahim
Member availability (exams, other courses)	Medium	Medium	Two items per person; stretch items are the first cut; status update in the team channel every Monday, Wednesday, Friday.	All

4.7 Deferred to a Later Sprint

Item	Reason
F3 file upload validation (#46 to #62)	Large; depends on storage policies being verified by S6.
Live analytics replacing mock data; notifications table	Need the real data path from S4 first.
Pagination; F12 filtering and search	Performance work with little value until real data exists.
F13 and F20 audit logs	Partly covered by F5 logging; scope needs review against F5.
Front-end RBAC route guards (#94 to #96)	Database enforcement comes first; UI hiding is not security.
Sentry; accessibility pass; F1 rules verification	See revisions 8 and 9; accessibility planned for Sprint 2 alongside F3 form changes.

4.8 Definition of Done

- Code merged to main through a PR with one teammate approval.
- CI passes: typecheck, lint, tests, build.
- Acceptance criteria in 4.2 met and noted in the PR description.
- Issue closed with a link to the PR; board updated.

5. AI Plan vs Final Plan at a Glance

Aspect	Agent output	Final plan
Sprint goal	Five outcomes, not testable	One outcome with a defined demo test
Committed items	18 (3 Large)	10 (none Large) + 2 stretch
Dependencies	2 stated, none sequenced	11 links, critical path identified
Ownership	2 to 6 items per person	2 items per person plus reviewer
Acceptance criteria	None	Per item, plus definition of done
Factual errors	3 (test setup missing, .env not tracked, PRs mergeable)	Corrected using repo and GitHub evidence
Risks	7 generic	6 with likelihood, impact, mitigation, owner